Capítulo 06

Gestión de operaciones y comunicaciones

Objetivos

Describir responsabilidades, seleccionar y aplicar controles y procedimientos de gestión de operaciones y comunicaciones.

Conceptos

Definición, procedimientos y responsabilidades de la gestión de operaciones y la gestión de la seguridad de la red.

Ejercicio de nivelación -gestión de las operaciones y las comunicaciones

- ¿Qué entiende usted por gestión de operaciones y comunicaciones?
- ¿Cómo realiza su organización la gestión de las operaciones y las comunicaciones?

6.1 Objetivos

La gestión de las operaciones y comunicaciones tiene como fin garantizar que se cumplan los requisitos de seguridad de la información, teniendo en cuenta el funcionamiento de los recursos computacionales y las comunicaciones en la organización.

Por lo tanto, esta gestión incluye el tratamiento de los servicios subcontratados, la protección contra códigos maliciosos, la política de copias, la seguridad de redes, medios y transferencia de software e información, además de la vigilancia global de todos los aspectos de las operaciones y las comunicaciones dentro de la organización.

6.2 Procedimientos y responsabilidades operacionales

Con respecto a los procedimientos y las responsabilidades operativas, algunas prácticas son consideradas esenciales, con el objetivo de garantizar la adecuación de las operaciones a los requisitos de seguridad de información de la organización. Esas prácticas se detallan a continuación:

- Documentar los procedimientos operacionales de manera formal y flexible (en el sentido de permitir cambios cuando sea necesario y autorizado) englobando el tratamiento de las operaciones de mantenimiento, manipulación de errores, y otras condiciones adversas, los contratos de soporte, los procedimientos de recuperación, generación de copias de seguridad, entre otros.
- Controlar cambios operativos, definiendo las responsabilidades de gestión y, cuando sea posible, integrar los procedimientos de control de cambios para las aplicaciones y sistemas operativos. Es importante mantener un registro de auditoría cuando se realizan cambios.
- Establecer procedimientos para la gestión de incidentes, como acción para garantizar una respuesta rápida, eficaz y ordenada a los incidentes de seguridad.
- Separar las responsabilidades, con el fin de reducir los riesgos de mal uso de los sistemas, por ejemplo, impidiendo que una única persona pueda acceder, modificar o utilizar los activos sin autorización. Por lo tanto, es importante separar la gestión de ciertas responsabilidades o áreas de responsabilidad para que las posibilidades de modificaciones no autorizadas se reduzcan.
- Separar instalaciones de desarrollo, pruebas y operación, estableciendo un nivel de separación necesaria para evitar problemas de funcionamiento, sobre todo en términos de acceso o modificaciones no autorizadas. Por ejemplo, las reglas para cambiar el estado de un software (de desarrollo a producción) deben ser definidas y documentadas.

Ejemplo: el tratamiento de las responsabilidades operativas:

- "Los usuarios que utilicen los sistemas de las TI de la organización deben firmar un contrato de responsabilidad antes de acceder a ellos. La firma del contrato significa que el usuario entiende y está de acuerdo con las políticas y normas de seguridad y tiene conocimientos sobre la legislación vigente y aplicable en los casos de incumplimiento".

En el ejemplo, se presenta una regla que hace referencia a contrato de responsabilidad que determina, a su vez, todas las responsabilidades de los usuarios relacionadas con el correcto funcionamiento de los sistemas de las TI de la organización, de acuerdo con las políticas y normas de seguridad de la información vigentes, y también determina la aplicación de la Ley en caso de incumplimiento.

La planeación anticipada es importante para garantizar los recursos necesarios para los sistemas, lo que facilita su adopción en la organización. En este contexto, son importantes la planificación de capacidad y un proceso adecuado de homologación.

En la planeación de capacidad, se atienden las demandas por capacidades futuras, con el fin de proporcionar el poder de procesamiento y almacenamiento adecuados a los requisitos de la organización. También es saludable la preocupación por las tendencias con respecto a las aplicaciones y sistemas de información, entre otros aspectos influyentes en el contexto.

En cuanto a la homologación, es importante determinar de antemano los criterios de aprobación y aceptación, y las pruebas adecuadas para los sistemas. Algunos criterios relevantes son: rendimiento, capacidad de procesamiento, recuperación de errores, planes de contingencia y medidas de seguridad adoptadas. En particular, todos los criterios y supuestos considerados para la aprobación deben ser definidos, acordados, documentados y probados.

Ejercicio de refuerzo - procedimientos y responsabilidades operacionales

- Explique la práctica de la segregación de responsabilidades.
- Explique cómo debe ser la planificación de capacidad.

6.3 Protección contra software malicioso

Hay varias posibilidades, tales como virus, troyanos, bombas lógicas, etc. La protección debe estar basada en crear conciencia sobre la seguridad, control de acceso y el cambio. Algunas de las prácticas son:

- Controlar la conformidad de las licencias de software.
- Controlar los riesgos asociados a los archivos y software obtenidos a través de la red.
- Instalar y actualizar periódicamente los antivirus.

Dada la variedad de *malware* existente actualmente, es de suma importancia asegurar controles en relación con los recursos de procesamiento de información y software en las organizaciones. Algunas prácticas pueden aplicarse al contexto, como el uso de software para detectar *malware*, antivirus, control estricto de acceso, un control adecuado de cambios, prohibición del uso de software no autorizado y precauciones con archivos y software obtenidos a través de la red.

También se recomiendan algunas comprobaciones: revisar la presencia de código malicioso en archivos y medios ópticos o electrónicos transmitidos a través de la red, recibidos por correo electrónico, páginas web, tanto en los servidores como en las estaciones de trabajo de los funcionarios de la organización.

Reglas para la protección contra códigos maliciosos:

- No abrir los archivos o ejecutar programas adjuntos a mensajes de correo electrónico sin verificar primero con un programa de detección de virus.
- No utilizar formatos ejecutables en los archivos comprimidos, dado que este formato facilita la propagación del virus.
- Usar software licenciado para su uso por la organización, de acuerdo con las disposiciones específicas establecidas en el contrato.

En el ejemplo, se presentan las normas que rigen para cualquier organización, con el objetivo de establecer recomendaciones para la protección contra códigos maliciosos y que puedan provocar incidentes de seguridad. En particular, también se presenta una regla para la instalación de programas, como una medida preventiva para la instalación de software malicioso.

Ejercicio de refuerzo - protección contra software malicioso

- ¿Cuáles son algunas de las prácticas que se pueden aplicar para la protección contra software malicioso? De ejemplos.
- Cite algunas reglas que se pueden aplicar en su organización.

6.4 Las copias de seguridad

Las copias de seguridad (*backups*) representan los controles destinados a garantizar la integridad y disponibilidad de los activos. En este contexto, se debe prestar atención no sólo a la generación de copias, sino también a que la generación se haga con regularidad y sea probada, y que la recuperación se lleve a cabo en un tiempo aceptable.

Se recomiendan algunas prácticas para el tratamiento de las copias de seguridad:

- Registrar y documentar los procedimientos de recuperación a partir de copias de seguridad;
- Definir el modo (ya sea completa o incremental) y la frecuencia de generación de las copias, de acuerdo a la criticidad de los activos y a los requerimientos del negocio y de seguridad de la organización;
- Almacenar las copias en lugares remotos o suficientemente distantes para no ser afectados por los desastres ocurridos en la ubicación específica de la organización;
- Identificación de los niveles adecuados de protección física y ambiental de las copias;
- Aplicar pruebas regulares a los medios utilizados en la generación de copias;
- Probar regularmente los procedimientos de recuperación.

Las copias de respaldo deben mantener duplicados de la información esencial para el negocio y deben ser probadas con regularidad para cumplir con los requisitos de los planes de continuidad del negocio.

Ejercicio de refuerzo - copias de seguridad

- ¿Cuáles son los objetivos de las copias de seguridad?
- ¿Cuáles son algunas de las prácticas que se pueden aplicar en su organización?

6.5 Políticas de copias de seguridad

Mantener las copias de seguridad completas y actualizadas son una actividad importante en los planes de contingencia de la organización, dado que permiten comparar los sistemas y datos actuales con las copias de seguridad en caso de problemas y luego hacer la recuperación adecuada.

La política de seguridad se determina de acuerdo con el grado de importancia de los sistemas y de la información para el negocio de la organización; por eso, establece los procedimientos, las pruebas y la infraestructura necesaria para la protección de copia de seguridad con el fin de garantizar la continuidad del negocio en caso de desastre o incidente de seguridad.

En términos de estrategias, se puede determinar copias de seguridad completas o incrementales (en uno o más niveles) con frecuencia variable en función de la importancia del sistema o de la información en cuestión.

Ejemplos

Reglas para el tratamiento de las copias de seguridad:

- A cada empleado le corresponde realizar regularmente, una copia de seguridad de sus datos.
- Mantenga un registro de las copias creadas de seguridad.
- Guarde las copias de seguridad en un lugar seguro y diferente de donde se encuentra la información original.
- En el ejemplo, se presentan las reglas aplicables a cualquier organización, con el objetivo de establecer las prácticas relacionadas a la generación y mantenimiento de copias de seguridad.

Ejercicio de refuerzo - políticas de copias de seguridad

- ¿Cómo debe ser determinada la política de copias de seguridad?

6.6 El tratamiento de los medios y documentos

Los medios magnéticos (discos, cintas, DVD/CD, etc.) y la documentación deben estar protegidos de las amenazas por interrupción, interceptación, modificación y fabricación. Por lo tanto, algunas prácticas son aplicables:

- Tener en cuenta la clasificación de la información antes de establecer los procedimientos y medidas de seguridad para su procesamiento, almacenamiento y transmisión;
- Controlar el acceso al contenido de medios y documentos;
- Desechar de forma segura medios y documentos que ya no son útiles, con base en los procedimientos formales. Por ejemplo, usando incineración o trituración;
- Para el trasporte de medios se deben establecer reglas claras en cuanto a los transportadores, el embalaje, los modos de entrega (en mano, por correo, etc.).

Ejercicio de refuerzo - tratamiento de medios y documentos

- ¿Cuáles son las dos prácticas que se deben adoptar en su organización para el tratamiento de los medios y documentos?

6.7 Gestión de la seguridad de la red

Es importante utilizar medidas de seguridad de red adecuadas en las organizaciones, de acuerdo con la política de seguridad y los requisitos legales, contractuales y reglamentarios. Para ello, se recomienda tener en cuenta las responsabilidades operativas de la red y los procedimientos necesarios (incluyendo el acceso remoto) para coordinar su gestión.

Se recomiendan algunas prácticas para este contexto:

- Separar las responsabilidades operativas de la red de otras operaciones;
- Identificar los requisitos de seguridad, niveles de servicio y los requisitos de gerencia de servicios de red para la organización (ya sea interno o subcontratado). Los servicios de red incluyen,

por ejemplo, las conexiones y el suministro de soluciones de seguridad tal como *firewalls*;
- » Determinar responsabilidades y los procedimientos adecuados para la gestión de la red y de los equipos remotos;
- » Aplicar las medidas de seguridad que garanticen la confidencialidad e integridad de los datos en tráfico y la disponibilidad de los recursos involucrados en las comunicaciones.

Ejercicio de refuerzo - gestión de seguridad de la red

- » Cite dos prácticas que se deben adoptar en su organización para la gestión de seguridad de la red

6.8 La transferencia de información y el software

Se debe garantizar la seguridad en cualquier modalidad de transferencia (interna o entre la organización y terceros) de la información y software. Es de destacar que, por el contexto, estos recursos se consideran relevantes: e-mail, voz, video, comercio electrónico, descargas de software y la compra a los proveedores, por ejemplo.

En particular, la transferencia de información y software entre organizaciones debe llevarse a cabo bajo las reglas de una política formal específica (o acuerdos específicos) y los requisitos legales, contractuales y reglamentarios vigentes.

En general, las siguientes prácticas pueden ser consideradas:

- » Protección contra software malicioso;
- » Definir claramente las reglas para el uso de los recursos electrónicos, como el correo electrónico y los servicios web. Por ejemplo, la restricción de las retransmisiones de mensajes de correo electrónico a direcciones externas de correo electrónico;
- » Establecer procedimientos para el uso seguro de la comunicación inalámbrica (*wireless*);
- » Garantizar que los recursos utilizados en la transferencia de información y de software cumplen con la legislación vigente;
- » Declarar claramente las responsabilidades de las partes involucradas en los casos de ocurrencia de incidentes de seguridad.

6.9 Monitoreo

El monitoreo de las operaciones y las comunicaciones debe ser una tarea regular y con el apoyo de los líderes de la organización, con el fin de garantizar la adecuada seguridad de la información con relación a los recursos operativos y de comunicación disponibles, y de acuerdo a las necesidades que surgen tras el análisis/evaluación de riesgos de seguridad de la organización. También se recomienda que todos los eventos relacionados con el monitoreo se registren correctamente a través de los *logs* de funcionamiento, de fallas y de auditoría, por lo menos.

En particular, las actividades de vigilancia y el registro se llevarán a cabo de conformidad con la legislación vigente. Todos los *logs* deben ser protegidos contra el acceso no autorizado.

Las siguientes prácticas pueden ser adoptadas para el mantenimiento adecuado de los registros:

- El *log* de operaciones debe mantener información tal como las actividades de los operadores y administradores de sistemas, el horario de inicialización y cierre de sistemas, errores y acciones correctivas implementadas, por ejemplo;
- El *log* de fallas debe registrar las fallas y las acciones correctivas tomadas. En particular, es importante que existan reglas claras para el manejo de reportes de fallas en la organización

Los *logs* de auditoría se deben mantener con el fin de registrar las actividades del usuario, los problemas de seguridad, los cambios de configuración de los sistemas, todos los accesos realizados, por un período adecuado de tiempo para las actividades de auditoría y supervisión .

Ejemplos de procedimientos con los *logs*:

- "No se permite el acceso no autorizado al correo electrónico de terceros. Los intentos de acceso deben ser registrados en *log*, incluyendo los causados por los administradores del sistema. "
- "Debería ser posible reconstruir todas las actividades de los usuarios a partir de los *logs*. Los procedimientos utilizados para dicha supervisión deben tener en cuenta los mecanismos claros y divulgados de responsabilidad en los medios de comunicación internos de la organización. "

Se ejemplifican algunos procedimientos relevantes a considerar en cuanto a la generación de *logs* en la organización. Los ejemplos pueden ser considerados para organizaciones reales y su objetivo es permitir el monitoreo de las operaciones y actividades de los usuarios en particular.

Capítulo

07

Seguridad de acceso y del entorno

Objetivos

Describir los procedimientos y responsabilidades y seleccionar y aplicar los controles y procedimientos de seguridad de acceso y del entorno.

Conceptos

Política de control de acceso, controles de acceso lógico y físico, control del entorno y seguridad en recursos humanos

Ejercicio de nivelación - seguridad de acceso y del entorno

- ¿Qué entiende por acceso físico?
- ¿Qué entiende por acceso lógico?

7.1 Política de control de acceso

La política de control de acceso debe ser definida y documentada por las organizaciones para garantizar las medidas y procedimientos de seguridad adecuados a los recursos físicos y lógicos, de conformidad con los requisitos del negocio. Por lo tanto, la política de control de acceso, al menos, debería tener en cuenta:

- Información manejada por las aplicaciones de negocio y los riesgos inherentes que hay;
- La clasificación de la información;
- La legislación, los requisitos reglamentarios y contractuales vigentes y pertinentes a la protección de acceso
- Requisitos para la autorización formal de las solicitudes de acceso y remoción de derechos;
- Requisitos para la comprobación periódica de los controles de acceso.

Tenga en cuenta que la política debe contemplar, en conjunto, los controles de acceso lógico y físico.

Clasificación de la información:

Proceso para la definición de la sensibilidad de la información y quién tiene acceso a esta información, lo que permite definir los niveles de acceso y criterios que garanticen la seguridad de la información.

Ejercicio de refuerzo - políticas de control de acceso

» ¿Qué se debe tener en cuenta en la política de control de acceso?

7.2 Controles de acceso lógico

En términos de control de acceso lógico, se verán a continuación sub-temas que abordan las principales preocupaciones y mejores prácticas para el contexto, además presenta los aspectos claves para el control de acceso lógico conforme a los requisitos de seguridad global y de negocios de las organizaciones.

El control de acceso lógico comprende un conjunto de medidas y procedimientos adoptados por la organización o intrínsecos al software y sistemas utilizados, y tiene como objetivo proteger los recursos informáticos y la información, para asegurar:

» Que sólo los usuarios autorizados tengan acceso a los recursos y que estos recursos son los realmente necesarios para el desempeño de sus actividades;
» Que el acceso a los recursos críticos sea restringido y supervisado adecuadamente. En otras palabras, se puede considerar que el control de acceso lógico es un proceso que utiliza las medidas preventivas y procedimientos específicos para que los usuarios o procesos accedan a los recursos de modo adecuado.
» Cuando se trata de control de acceso, primero se deben identificar los recursos a proteger. Éstos son algunos típicamente identificados en las organizaciones: aplicaciones (código fuente y objeto), archivos de datos y contraseñas, redes, utilidades, sistemas operativos, archivos de *log*, entre otros.

Recuerde que capacitar a los usuarios es una tarea importante para garantizar la eficacia de las medidas y procedimientos adoptados para el control de acceso. Por lo tanto, una buena práctica es que los usuarios se mantengan informados sobre sus responsabilidades con el mantenimiento de los controles de acceso de la organización.



Estudie la sección 11 (Control de accesos) de la norma ISO / IEC 27002:2007. **Norma Española 2022 apartados 5.15 a 5.18 inclusive**

Las funciones directamente relacionadas con el control de acceso lógico son: identificación y autenticación, para usuarios y los procesos, y atribuciones, gestión y monitoreo de los derechos de acceso o privilegios que indican exactamente el grado de autorización de acceso:

- **Identificación:** cada usuario/proceso que puede acceder a los recursos computacionales se debe identificar exclusivamente en el ambiente, por ejemplo, vía *login*, para permitir el control de acciones mediante *logs*.
- **Autenticación:** más allá de la identificación, el usuario deberá proporcionar alguna información complementaria para probar que esta es su verdadera identidad. Por ejemplo, un usuario realiza un inicio de sesión en una estación de trabajo debe informar su identificación (*login*) y contraseña, este es el autenticador que permite que el sistema compruebe si la identidad del usuario es correcta. Por lo tanto, la autenticación tiene como objetivo proporcionar una forma de verificación de la identidad de los usuarios/procesos antes de que obtengan acceso a los recursos. Por lo tanto, hay básicamente tres formas posibles: prueba por características (físicas), prueba por posesión y pruebas de conocimiento. Por ejemplo, usando reconocimiento facial o de voz, *smart cards* y contraseñas (*token*), respectivamente.
- **Atribuciones:** la asignación de derechos y permisos de acceso se puede determinar en dos aspectos: lo que un usuario/proceso puede hacer o lo qué se puede hacer con un recurso determinado. En la primera posibilidad, cada usuario o recurso recibe un permiso que, a su vez, define todos los derechos de acceso a otros recursos. En la segunda, se utilizan listas de control de acceso (*Access Control List, ACL*) para cada recurso, definiendo así los derechos de acceso de otros recursos o usuarios sobre el recurso asociado con estas listas.
- **Monitoreo:** se puede hacer mediante la verificación de *logs*, registros de auditoría, los mecanismos de detección de intrusos, entre otros, que pueden servir para tomar decisiones con res-

pecto a las medidas correctivas adecuadas en caso de incidentes de seguridad.

» **Gestión:** responsable de aplicar las medidas adecuadas a los riesgos inherentes a controles de acceso lógico inadecuadas, de acuerdo con las determinaciones dispuestas en controles de políticas de seguridad.

La gestión de los controles de acceso lógico debe implementar medidas que reduzcan los riesgos, observando, por lo tanto, algunas consideraciones definidas en la política de seguridad de la organización, a saber:

» Clasificación de los sistemas e información;
» Necesidades de obtención de acceso a sistemas y datos;
» Responsabilidades de los usuarios;
» Los valores de los activos;
» Otra información relevante para un adecuado control de acceso lógico.

En particular, cuando se trata de la gestión de control de acceso lógico, con respecto a la autorización, es importante tener en cuenta el mantenimiento adecuado de los derechos de acceso a los nuevos recursos y el uso de dispositivos móviles (*notebooks*, agendas electrónicas, teléfonos inteligentes, etc.) según su riesgo inherente.

Los ejemplos de las recomendaciones para el uso de contraseñas en la gestión de los controles de acceso lógico son:

» "Es el deber de la gestión de la seguridad deshabilitar las cuentas inactivas y sin contraseñas o con contraseñas estandarizadas."
» "La contraseña inicial de usuarios se debe generar de modo que ya esté caducada, obligando a la entrada de una nueva contraseña en el primer inicio de sesión."
» "Las cuentas de usuario se deben bloquear después de un número de intentos de acceso sin éxito."

Estos son ejemplos de las recomendaciones para los procesos de autenticación basados en contraseñas que se pueden utilizar en las organizaciones reales.

Se recomienda guiar a los usuarios para elegir contraseñas más seguras, evitar el uso de contraseñas demasiado cortas o demasiado largas (es recomendable utilizar ocho caracteres), lo que puede causar efectos secundarios tales como escribir las contraseñas en papel, evitando por otra parte, el uso de la misma contraseña para acceder a sistemas/

recursos diferentes. Es interesante, también, el uso de generadores de contraseña aleatoria, aumentando la confiabilidad de los sistemas de autenticación.



Para obtener información sobre las mejores prácticas en el uso de contraseñas, consulte:
https://security.web.cern.ch/security/recommendations/en/passwords.shtml
http://www.csirt.pop-mg.rnp.br/docs/senhas.pdf

Para el manejo adecuado de los controles de acceso lógico en una organización, se recomiendan algunas de las mejores prácticas:

- Asignar derechos de acceso a los usuarios, de acuerdo con las necesidades reales de su trabajo/cargo;
- Revisar las listas de control de acceso y capacidades de forma regular;
- Proporcionar cuentas de usuario sólo a las personas autorizadas;
- Almacenar contraseñas encriptadas;
- Mantener y analizar los *logs* y los registros de auditoría.

Ejercicio de refuerzo - controles de acceso lógico

- ¿Qué funciones están directamente relacionadas con el control de acceso lógico?
- ¿Qué se debe considerar al tratar la gestión de control de acceso lógico con respecto a la autorización?
- Nombre dos buenas prácticas para la gestión de los controles de acceso lógico de su organización.

7.3 Controles de acceso físico

Se verán, a continuación, las principales preocupaciones y las mejores prácticas para el control de acceso físico, con la presentación de los aspectos fundamentales y las influencias provenientes de las exigencias de seguridad global y de negocios de la organización.

Los controles de acceso físico están destinados a poner en práctica medidas preventivas para proteger a los equipos, documentación, suministros e información contra el acceso no autorizado, pérdidas, etc. Por lo tanto, estos controles sirven como una barrera de seguridad adicional para el control de acceso lógico.

También se debe considerar el uso de las áreas protegidas y los perímetros de seguridad. En las áreas protegidas (con estricto control de acceso), se recomienda el tratamiento de la información crítica para el negocio de la organización. Los perímetros de seguridad protegen las áreas que tienen instalaciones de procesamiento, por ejemplo, un control de acceso con registro y supervisión efectiva.

En cuanto a los controles de acceso físico, hay dos categorías, a saber:

- **Controles administrativos:** incluyen las medidas y los procedimientos administrativos para la protección física de la organización. En términos prácticos, se recomienda, en este contexto, la aplicación de formas de identificación única para personal y para visitantes, e incluso las categorías de los funcionarios; exigir la devolución de los activos de la organización en caso de despido de los empleados; controlar la entrada/salida visitantes; exigir "escritorio limpio" y organizado, entre otros;
- **Controles explícitos:** implementados mediante el uso de cerraduras, candados, cámaras de video, alarmas y guardias de seguridad, por ejemplo.

Ejemplo de recomendación para el control de acceso físico a los equipos:

- "El acceso a equipos específico de hardware debe limitarse a personal competente, con uso registrado y basado en las necesidades de la organización."

En este ejemplo, se presenta una recomendación para el control de acceso físico en las organizaciones, y se pueden incluir en organizaciones reales como elemento de la política de control de acceso y de la política de seguridad.

La gestión de los controles de acceso físico debe tratar de averiguar los riesgos potenciales y los impactos causados por los incidentes originados por fallas de seguridad físicas, aplicando medidas adecuadas para la organización.

Tenga en cuenta que, como se dijo anteriormente, las medidas y los procedimientos de los controles de acceso físico deben ser incluidos en la política de control de acceso, apoyando la política de seguridad de la información de la organización y, en consecuencia, dichos documentos en conjunto apoyan la gestión de los controles de acceso físico.

Entre las mejores prácticas para el adecuado control de acceso físico (y su gestión), se encuentran:

- Use técnicas de identificación visibles;
- Exigencia de la devolución de los activos de la organización cuando el empleado es despedido o separado de sus funciones;
- Supervisar la entrada y salida de visitantes, registrando la fecha, el tiempo de permanencia y el lugar visitado (sector, departamento, etc.)
- Determinar la vigilancia permanente (7 x 24) en la organización;
- Revisar y actualizar periódicamente los derechos de acceso;
- Fomentar la política de escritorio limpio, entre otros.

Ejercicio de refuerzo - controles de acceso físico

- ¿Cuál es el propósito de control de acceso físico?
- ¿Cuáles son los controles explícitos y controles administrativos?
- Nombre dos buenas prácticas para la gestión de los controles de acceso físicos de su organización.

7.4 Controles ambientales

En términos de control ambiental, se presentan algunas de las prácticas específicas para reducir los riesgos asociados a amenazas en el entorno de las organizaciones, de acuerdo con los requisitos del negocio y la seguridad global.

Los controles de ambiente tienen por objeto proteger a la organización en términos, específicamente, de la disponibilidad y la integridad de sus recursos, es decir, contra los desastres naturales y las fallas en el suministro o descargas de energía eléctrica, por ejemplo.

Dependiendo de la amenaza, se pueden establecer las medidas preventivas y/o correctivas. Se presentarán las siguientes mejores prácticas para garantizar los controles ambientales apropiados.

A continuación tenemos una lista de las principales amenazas y las medidas de control aplicadas:

- **Los incendios:** se aconseja el uso de dispositivos de detección de humo o calor, instalación de pararrayos, la adopción de políticas de ambientes libres de humo, la disposición de un número suficiente de extintores de incendios, la instalación de los sistemas automáticos de extinción de incendios, la verificación regular de todos los dispositivos contra incendios y el entrenamiento de los empleados en cuanto a su uso;
- **Las fallas en la electricidad y las descargas eléctricas naturales:** se recomienda el uso de estabilizadores, UPS, generadores alternos de energía, la instalación de pararrayos, apagado del equipo en situaciones de fuertes tormentas;
- **Las amenazas relacionadas con el agua:** es pertinente la instalación de los equipos en lugares con baja susceptibilidad al agua, mantenimiento adecuado de los tejados, red de alcantarillado y equipos de aire acondicionado;
- **Temperatura y ventilación:** deben ser considerados en este caso, el cuidado de los canales de ventilación, la circulación de aire, dispositivos que ayudan en el control de la temperatura y la ventilación del ambiente y el mantenimiento periódico de este equipo

A continuación se presenta una lista de las mejores prácticas para garantizar el control adecuado del entorno en las organizaciones:

- Planificar la ubicación de muebles y equipos, facilitando la circulación de las personas;
- Mantener la limpieza y conservación del ambiente;
- Implementar sistemas automáticos de extinción de incendios;
- Instalar los dispositivos que minimicen los efectos de las fallas en suministro de energía eléctrica;
- El mantenimiento adecuado de potenciales focos de problemas con agua;
- Inspeccionar regularmente todos los dispositivos directamente relacionados con la conservación de la seguridad del ambiente.

Ejercicio de refuerzo – controles del entorno

» ¿Cuál es el propósito de los controles del entorno?
» Nombre dos buenas prácticas recomendadas para la gestión de los controles de acceso físicos en su organización

7.5 Seguridad de recursos humanos

En esta sección serán presentados algunos de los principales aspectos de la seguridad de la información en las organizaciones; la seguridad de los recursos humanos, el cual, a su vez, es uno de los pilares para la seguridad de la información adecuada y concientizada en términos de los posibles errores humanos. Será vista en algunas prácticas y preocupaciones para el tratamiento de las personas, desde la selección, considerando también la capacitación en términos de seguridad de la información.



Estudie la sección 8 (recursos humanos de seguridad) de la norma ISO/IEC 27002:2007.
Norma Española 2022 apartados 6.1 a 6.7 inclusive

La selección de los candidatos deberá ser estricta en función, principalmente del cargo deseado y su criticidad para el negocio. Tenga en cuenta que el "candidato" puede representar un posible empleado, un empleado que busca cambiar de cargo o incluso un prestador de servicios.

Durante la selección de las personas, la organización debe dejar claro las responsabilidades y funciones de los candidatos en caso de contratarlos, frente a la seguridad de la información, a través de la presentación de una descripción detallada y de los términos y condiciones del contrato.

Por lo tanto, es importante destacar, en los documentos a ser firmados por el contratista, requisitos como actuar de acuerdo con la política de seguridad de la información y notificar a los superiores respecto a los eventos adversos que pueden caracterizar riesgos de seguridad de la organización.

La selección en sí, como se dijo antes, debe ser lo suficientemente estricta como para contemplar la verificación de referencias personales satisfactorias; confirmación de las calificaciones académicas y profesionales, y también puede considerar verificaciones financieras (crédito) y de registros penales. Es de destacar también que pueden ser relevantes, dependiendo de la situación, una selección estricta de proveedores y contratistas.

Los términos y condiciones deben estar claramente establecidos en el contrato, por lo que éste se firma indicando que el contratista está de acuerdo con sus responsabilidades relacionadas con la seguridad de la información de la organización (incluyendo las responsabilidades legales). En este contexto, también es conveniente la orientación para que se siga un código de conducta y se firme un acuerdo de confidencialidad antes de facilitar el acceso al contratista.

El acuerdo de confidencialidad debe incluir requisitos para la protección de la información confidencial, teniendo en cuenta la legislación vigente. En particular, el contenido debe comprender por lo menos una definición de la información a proteger, la duración del acuerdo, las responsabilidades y las acciones de los involucrados para evitar la divulgación no autorizada, el alcance de los derechos de los empleados en el uso de la información, los derechos de auditoría y monitoreo, y las acciones específicas en caso de violaciones al acuerdo.

Al cancelar o cambiar el contrato de un empleado (o tercero), es importante que la organización facilite los medios adecuados para un proceso ordenado y coordinado.

En este contexto, algunas prácticas son aplicables:

- Tras la terminación de una función, una comunicación debe informar acerca de los requisitos de seguridad y las responsabilidades legales exigidas;
- Devolución de activos, tales como equipos, documentos, software, computadores portátiles, tarjetas de crédito, tarjetas de acceso, carnets, etc.;
- Retire los derechos de acceso a la información y recursos. En caso de cambio de cargo, se deben revisar los derechos, con

el fin de no permitir accesos que no han sido aprobados para la nueva función. Si, por ejemplo, el empleado con actividades finalizadas en la organización tiene conocimientos acerca de las contraseñas de las cuentas que se mantienen activas después de su partida, estas deben ser cambiadas.

Ejercicio de refuerzo - seguridad recursos humanos

» ¿Durante el proceso de desvinculación de la organización de un colaborador por finalización del contrato, qué se debe hacer?

Si los empleados o terceros no están realmente conscientes en cuanto a sus responsabilidades y obligaciones con la seguridad de la información de la organización, pueden considerarse en sí mismos como riesgos, y pueden causar impactos al negocio.

Por lo tanto, se debe promover entrenamiento regular, conferencias y actividades de divulgación de directrices para la seguridad de la información a todas las personas, de modo que conozcan los procedimientos de seguridad, que hagan un uso adecuado de los recursos, servicios ofrecidos e información.

En los procesos de capacitación para la seguridad de la información, es importante concientizar a las personas en términos de riesgos, e informarles a quién deben reportar eventos adversos y como buscar orientación.

A través de iniciativas de educación en seguridad de la información, es posible minimizar los riesgos, dado que las personas son sensibilizadas a seguir las reglas de seguridad de la información en su vida cotidiana.

Ejemplo de recomendación para la conducta de las personas ante el uso de recursos de información crítica:

» "La organización se reserva el derecho de revocar los privilegios de usuario de cualquier sistema y en cualquier momento debido a un comportamiento ofensivo o dañino o incluso que afecte la capacidad de otras personas para realizar correctamente sus funciones.

En este ejemplo se presenta una recomendación para el tratamiento de las personas en las organizaciones, en particular las normas explícitas para su conducta hacia los negocios y la manipulación de los recursos y la información crítica. Esta recomendación también se puede aplicar para una seguridad eficiente del recurso humano.

Capítulo

08

Seguridad organizacional

Objetivos

Describir los procedimientos y responsabilidades, y seleccionar y aplicar controles de seguridad organizacional.

Conceptos

Infraestructura organizacional para la seguridad de la información, el tratamiento de los activos y la seguridad de la información de terceros.

Ejercicio de nivelación - seguridad organizacional

- ¿Qué se entiende por seguridad organizacional?
- ¿Cómo se hace la seguridad organizacional en su institución?

8.1 Infraestructura organizacional para la seguridad de la información

En esta sección se presentarán los temas relevantes para el establecimiento de una infraestructura de apoyo a la seguridad de la información en las organizaciones. En particular, se tratará la importancia de la infraestructura, la relevancia de la asignación de responsabilidades y aspectos relacionados con la coordinación.

8.1.1 Importancia de la infraestructura

Para garantizar la seguridad de la información de una organización en particular, se debe prestar atención a la necesidad de establecer una infraestructura que fomente la gestión. Inicialmente, es válido definir una estructura de gestión propia para el control de la implementación de seguridad de la información.

En particular, si fuere el caso, es relevante la contratación de una consultoría especializada con el propósito de elaborarla e implantarla en la organización.

8.1.2 Asignación de responsabilidades

Asignar responsabilidades se considera una actividad crucial para la seguridad de la información y se debe realizar de acuerdo con la política de seguridad de la información de la organización.

Los funcionarios (o personas en ciertas posiciones) que tengan responsabilidades definidas formalmente en la política de seguridad pueden delegar directamente las actividades relacionadas con la seguridad de la información, sin embargo, no se eximen de su responsabilidad. Por lo tanto, es relevante que en el caso de delegación, los funcionarios que delegan la actividad evalúen si ésta se lleva a cabo conforme a la política de seguridad, la legislación y las normas vigentes.

Para cada activo y procedimiento de seguridad de la información, es importante asignar responsabilidades a un funcionario (o cargo). En otras palabras, el funcionario (o cargo) debe realizar la gestión del activo o del procedimiento según se determine en la política de seguridad.

Dependiendo del tamaño y de las vulnerabilidades de la organización, se puede establecer el cargo de gestor de seguridad de la información, que es responsable en primera instancia, de la seguridad general de la organización y también ayuda en el desarrollo de la política de seguridad y define la estrategia para su divulgación, exigiendo el cumplimiento por parte de todos. El gestor, debe estar siempre actualizado sobre los problemas, riesgos y soluciones de seguridad; seleccionar los mecanismos de seguridad más adecuados para los problemas de seguridad específicos de la organización; y verificar la adecuación de la política de seguridad, mecanismos y procedimientos de seguridad de la información que se adopten.

Ejercicio de refuerzo - asignación de responsabilidades

- ¿Qué tareas deben asignarse al gestor de seguridad de la información?
- ¿Por qué la asignación de responsabilidades es fundamental para la seguridad de la información?

8.1.3 Coordinación de la seguridad de la información

Para la efectividad de la seguridad de la información en una organización, sus líderes deben reunir un equipo multidisciplinario (directivos y funcionarios de varios departamentos, por ejemplo) para coordinar las actividades necesarias. Si es necesario, también se puede establecer un comité específico. En particular, se recomienda que actúe para coordinar las siguientes actividades:

- Evaluar y aprobar las metodologías y procedimientos para la seguridad de la información;
- Controlar todos los procedimientos, con el fin de garantizar el cumplimiento de la política de seguridad de la organización;
- Coordinar la implantación de los controles de seguridad de la información, tales como las medidas contra el acceso no autorizado;
- Divulgar adecuadamente a toda la organización los procedimientos, los controles y la política de seguridad. Recuerde siempre que la concientización de las personas puede ser considerada tan relevante como el uso de otros mecanismos de seguridad basados en la tecnología.

Ejercicio de refuerzo - coordinación de la seguridad de la información

- ¿En qué actividades debe actuar el comité?

8.2 Tratamiento de los activos

Teniendo en cuenta que los activos son elementos esenciales para el negocio de las organizaciones, esta sección presenta los aspectos principales a tener en cuenta. Se presentarán las preocupaciones sobre la protección de los activos y de los procedimientos recomendados, aplicados a la gestión de activos y recuperación de desastres: inventario y designación de propietario para cada activo de la organización.

8.2.1 Protección de activos

Los activos de la organización son elementos importantes para el negocio, por lo que una protección adecuada debe ser establecida y mantenida. Ejemplos:

- Equipos;
- Bases de datos;
- Servicios de iluminación;
- Acuerdos;
- Procedimientos de soporte técnico;
- Los registros de auditoría;
- Aplicativos;
- Sistemas de información;
- Personas;
- Imagen comercial de la organización.

Para tal protección se recomiendan dos procedimientos: hacer un inventario de los activos y asignar a cada uno un propietario, responsable por el mantenimiento de su seguridad.

A continuación se presentará más detalles acerca de cada procedimiento.

Ejercicio de refuerzo - protección de los activos

- ¿Qué son los activos?

8.2.2 Inventario de activos

En el inventario de los activos, se debe estructurar y mantener los activos debidamente identificados. En la identificación, las información relevante por lo general es: el tipo de activos, configuración, su criticidad para el negocio de la organización, la ubicación, la información sobre el tratamiento de *backups* y licencias. En el inventario también se deben identificar el propietario de cada activo y la clasificación de la información, cuando sea apropiado.

En el caso de recuperación de desastres, el inventario de activos es uno de los elementos esenciales para su efectividad. Y, para la gestión del riesgo, el inventario es una premisa.

Ejercicio de refuerzo - inventario de activos

» ¿Qué información debe incluirse en el inventario de los activos?

8.2.3 Propiedad de los activos

El propietario de un activo es el responsable de mantener su seguridad, realizando actividades tales como:

» Garantizar la clasificación adecuada de los activos;
» Definir y analizar, periódicamente, las restricciones de acceso al activo.

Son ejemplos de propietarios de activos el gerente de RRHH (Recursos Humanos) de la organización encargada de documentos específicos y el desarrollador responsable por su estación de trabajo. Es de destacar que, en caso necesario y apropiado, se puede atribuir al gestor de seguridad de la información la responsabilidad por ciertos activos, especialmente aquellos directamente relacionados con la seguridad de la información, tal como la propia política de seguridad.

Este ejemplo proporciona alguna información sobre el activo "base de datos" de una organización. Se puede observar que:

» El tipo considerado es "datos". La clasificación de los activos puede variar de una organización a otra, pero por lo general se pueden clasificar en hardware, software, datos, documentación, etc.
» La criticidad del activo se considera alto, teniendo en cuenta que los datos son esenciales para el negocio de la organización. Puede asociar la criticidad asignado a las categorías utilizadas en el análisis/evaluación de riesgos para la organización. A modo de ejemplo, los activos pueden ser clasificados como alta, moderada o baja criticidad.
» La ubicación del activo es la sala de servidores en toda la organización, dado que es una base de datos almacenada en una base de datos.
» El tratamiento aplicado al *backup* del activo es incremental y diario. Para todos los activos es relevante indicar la política de copia de seguridad para la gestión de incidentes, en particular. Para efectos de conocimiento, la política puede determinar, de conformidad con el grado de criticidad del activo, el *backup*

completo o incremental y su período (mensual, quincenal, semanal o diario, por ejemplo).

Por último, se asigna el responsable de la seguridad del activo. En este caso, el administrador de la base de datos de la organización.

Ejercicio de refuerzo - propietario del activo

» ¿Cuál es la responsabilidad del propietario del activo?
» Cite las actividades que debe realizar el propietario del activo.

3. Seguridad de la información de terceros

Es importante establecer procedimientos apropiados antes de facilitar el acceso por parte de terceros. En este tema, se tratará el por qué del tratamiento diferenciado de los terceros y los posibles riesgos involucrados; cómo tratar con los clientes en relación al mantenimiento de un acuerdo específico para el contexto y los procedimientos recomendados para la gestión de los servicios externalizados.

1. La razón del tratamiento diferenciado

Se debe considerar un tratamiento diferenciado a los recursos y la información que sean procesados, transmitidos o gestionados por partes externas, por ejemplo organizaciones de servicios, con el fin de permitir dicho acceso de conformidad con la política actual de seguridad de la información de la organización.

Por lo tanto, es importante hacer un análisis de los riesgos potenciales involucrados y las posibles medidas de seguridad adecuadas cuando se trata con partes externas. En particular, las medidas de seguridad y otros criterios específicos en cuanto a seguridad de la información deben ser definidas de común acuerdo entre las partes.

8.3.2 Posibles riesgos

En el tratamiento de la seguridad de la información en relación a terceros, existen riesgos potenciales específicos. Por lo tanto, es importante

analizar y evaluar los riesgos involucrados directamente con el acceso externo, aplicando las medidas de seguridad apropiadas antes de dar el acceso.

Los siguientes son algunos de los aspectos clave a considerar en el contexto:

- Identificar los recursos a los cuales los terceros pueden tener acceso;
- Indicar el tipo de acceso a cada uno de los recursos;
- Conocer el valor y la criticidad de la información a disposición de terceros;
- Aplicar las medidas de seguridad correspondientes a los riesgos para cada información accedida por terceros;
- Considerar las personas que pueden acceder a la información por parte de los terceros;
- Implantar prácticas y procedimientos para el manejo de incidentes de seguridad;
- Considerar los requisitos legales, contractuales y reglamentarios aplicables al contexto.

Ejemplo de normas para el tratamiento de terceros:

- "No se permite la revelación de identificación, autenticación y autorización para uso personal o uso de los recursos autorizados por medio de tales elementos por parte de terceros."
- "No está permitido proporcionar información a terceros acerca de los servicios disponibles en la organización, salvo las de carácter público o con autorización del equipo/gestor competente."

En este ejemplo se presentan reglas para el manejo de la información y servicios por parte de terceros, cuyo objetivo es demostrar la aplicación de procedimientos formales con miras a la seguridad de la información.

Ejercicio de refuerzo - posibles riesgos

- ¿Cuáles aspectos deben considerarse en relación con la seguridad de la información de terceros?

3. Tratamiento de los clientes

Al tratar con los clientes, la organización debe identificar, por anticipado, todos los requisitos de seguridad directamente relacionados con el acceso externo a los activos y a la información. Por lo tanto, se recomienda:

- Proteger los activos, utilizando mecanismos de seguridad adecuados e indicar las acciones correctivas que deben aplicarse en los casos de peligro;
- Describir en detalle el producto/servicio que va a prestar;
- Considerar las políticas de control de acceso existentes;
- Indicar las responsabilidades legales de la organización y del cliente.

4. Los acuerdos específicos

En los acuerdos, los requisitos de seguridad deben abordarse con el fin de garantizar el conocimiento y cumplimiento de los mismos por parte de terceros.

En esencia, se recomienda tener en cuenta en los acuerdos lo siguiente:

- La política de seguridad de la información existente;
- El uso de medidas de seguridad para la protección de los activos;
- Entrenamiento y sensibilización de las personas en términos de seguridad de la información y sus responsabilidades;
- Proceso claro de gestión del cambio;
- Políticas de control de acceso;
- Derecho a realizar las auditorías;
- Requisitos para la continuidad de los servicio;
- Responsabilidades legales, contractuales y reglamentarias aplicables.

Inclusive, pueden ser definidos acuerdos de confidencialidad, de manera que los requisitos de seguridad contemplados expresen las necesidades de la organización en cuanto al valor de la información para el negocio. Estos acuerdos protegen la información, al mismo tiempo que determinan las responsabilidades de los participantes en cuanto a la protección, el uso y la difusión de la información de la organización. Por lo tanto, los acuerdos de confidencialidad pueden ser establecidos entre la organización y terceros, y entre la organización y sus empleados.

En las organizaciones donde se externaliza la gestión de seguridad de la información, los acuerdos deberán proporcionar detalles sobre cómo los terceros garantizarán la seguridad acatando las obligaciones legales y los requerimientos del negocio.

8.3.5 Gestión de los servicios de terceros

Los servicios externalizados en una organización deben ser gestionados con el propósito de garantizar su adecuación a los requisitos de seguridad de la información y a los negocios. Por lo tanto, los acuerdos entre la organización y terceros deben ser gestionados y controlados adecuadamente. Prácticas apropiadas:

- Hay que tener en cuenta las medidas de seguridad, niveles de servicio y los requisitos de entrega de servicios en la elaboración de acuerdos de prestación de servicios externalizados. Tales acuerdos deben ser evaluados para verificar que se cumplen los requisitos de seguridad acordados;
- Es importante contar con soluciones técnicas y recursos suficientes para monitorear los acuerdos y los requisitos de seguridad establecidos;
- Se debe monitorear y analizar regularmente los servicios y *logs* proporcionados por terceros;
- Se debe gestionar los cambios en términos de servicios externalizados, teniendo en cuenta las posibles mejoras, actualizaciones de políticas, el establecimiento de nuevos controles de seguridad y uso de las nuevas tecnologías, por ejemplo.

Ejemplo:

- Cláusula contractual: seguridad de la información.

"El contratista se compromete a utilizar programas para la protección y la seguridad de la información que busquen prevenir cualquier acceso no autorizado a sus sistemas, ya sea en relación a los que estén, eventualmente bajo su responsabilidad directa, ya sea a través de un enlace con los demás sistemas del contratante o incluso mediante el uso de e-mail."

Capítulo

09

Gestión de la continuidad del negocio

Objetivos

Identificar los requisitos y organizar la continuidad del negocio; identificar y seleccionar los procedimientos de gestión de incidentes de seguridad.

Conceptos

Gestión de la continuidad del negocio, seguridad de la información y continuidad del negocio, plan de continuidad del negocio y gestión de incidentes.

Ejercicio de nivelación - gestión de la continuidad de negocios

» ¿Qué entiende usted por la continuidad del negocio?
» ¿Cómo es tomada la continuidad del negocio en su institución?

9.1 Continuidad del negocio

En este tema, se verán los aspectos importantes para la continuidad del negocio, así como para su gestión.



Estudie la sección 14: gestión de continuidad del negocio de la norma NTC ISO/IEC 27002:2007. . **Norma Española 2022 apartados 5.29 a 5.31 inclusive**

Hoy en día, las organizaciones dependen de la tecnología y los sistemas computacionales. Por lo tanto, la pérdida de los equipos y la información puede afectar el negocio de la organización, ocasionando pérdidas financieras, de mercado e incluso, dependiendo de la gravedad de las amenazas, provocando su disolución.

En este contexto, es más que necesario la toma de conciencia sobre la necesidad de recuperación de desastres y el plan de contingencia: ambos estratégicos para cumplir con los objetivos de negocio de la organización. Además, también es relevante el plan de continuidad de negocio.

Es de destacar que los líderes de la organización son responsables de revisar los recursos y la información con el fin de identificar la importancia de cada uno para la continuidad del negocio.

El plan de continuidad del negocio es responsabilidad de los líderes de la organización. El equipo de gestión de la seguridad puede ayudar en esta tarea, pero no puede ser responsabilizado por su completa implementación. Esta ayuda puede incluir la creación, mantenimiento, difusión y coordinación del plan de contingencias.

9.2 Gestión de la continuidad del negocio

La gestión de la continuidad del negocio combina la prevención y la recuperación, con el fin de evitar la indisponibilidad de los servicios y actividades del negocio, protegiendo así, los procesos críticos de los impactos causados por fallas o desastres y, en el caso de pérdidas, proporcionar la recuperación de los activos involucrados y restablecer el funcionamiento normal de la organización en un intervalo de tiempo aceptable. En particular, es esencial adoptar la definición de los procesos críticos de la organización y luego integrar la gestión de seguridad de la información de acuerdo con los requisitos de la gestión de la continuidad del negocio.

Algunos ejemplos de los procesos críticos son las operaciones generales, el trato de los funcionarios, los materiales, el transporte y las instalaciones, teniendo en cuenta, para el contexto, sus requisitos específicos de continuidad. Por lo tanto, es importante poner en práctica un plan de continuidad de negocio, con miras a la recuperación de los procesos críticos dentro del rango de tiempo aceptable para el negocio en caso de desastre. Es de destacar que el plan de continuidad del negocio es global para la organización, pero la seguridad de información debe ser considerada como uno de sus componentes.

Para más detalles acerca de la continuidad del negocio, ver las siguientes normas:

» ISO 22301:2012 de *Social security – Business continuity management systems - Requirements.*

Ejercicio de refuerzo - gestión de continuidad de negocio

- ¿Cuál es el propósito de la gestión de la continuidad del negocio?
- ¿Cuáles son los procesos críticos de su institución?

Prevención
Recuperación

9.3 Seguridad de la información y gestión de la continuidad del negocio

En este tema, se presentarán las principales consideraciones para integrar la seguridad de la información a la gestión de la continuidad del negocio. En particular, se trata el análisis de riesgos y su importancia para ambas.

La seguridad de la información debe ser contemplada como un elemento estratégico a considerar para la continuidad del negocio de una organización. Por lo tanto, cuando se trata de la inclusión de la información de seguridad en el contexto específico, se deben cumplir las siguientes consideraciones:

- La comprensión de los riesgos para la organización en términos de probabilidades e impactos;
- Identificación de los procesos críticos de negocio y los activos directamente relacionados;
- La comprensión de los impactos generados a los negocios por los incidentes de seguridad;
- Identificación de los contratos de seguro establecidos para los activos críticos de la organización;
- Identificación de las medidas preventivas, correctivas e ilustrativas aplicables;
- Identificación de los recursos financieros, de infraestructura, técnicos y ambientales necesarios para la recolección de los requisitos de seguridad;
- Consideración respecto a las medidas relacionadas con la seguridad en los recursos humanos;
- La consideración con respecto a las medidas para garantizar la protección de los recursos de procesamiento;
- La información detallada sobre los requisitos de seguridad de la información a ser incluidos;
- La formalización de las pruebas y del mantenimiento de los planes (de continuidad del negocio y de contingencias, por ejemplo).

Ejemplo de cuestiones a ser consideradas en el plan de continuidad del negocio:

» "La pérdida de la capacidad de protección, procesamiento y recuperación de la información manejada en computadores de la organización, que pueden causar problemas en la realización de sus negocios y no cumpliendo las metas previamente establecidas en el contrato con sus clientes."

El ejemplo presenta un problema que debe abordarse en el plan de continuidad del negocio de las organizaciones.

Ejercicio de refuerzo - seguridad de la información y la gestión de la continuidad del negocio

» ¿De acuerdo con el ambiente de su organización, cuál es la importancia de la comprensión de los impactos generados a los negocios por los incidentes de seguridad?

9.4 Análisis de riesgos y continuidad de negocio

La gestión de la continuidad del negocio debe comenzar por identificar los eventos adversos (identificación de las posibles amenazas), seguido de un análisis de riesgos; no sólo de seguridad, sino también de todos los procesos de negocio, con el fin de determinar el impacto de las interrupciones tanto en relación con la magnitud de los daños causados como en el período de recuperación. Ambas actividades deben llevarse a cabo con la plena participación de los responsables de los procesos y de los recursos de la organización.

Dependiendo de los resultados del análisis de riesgos, un plan específico debe ser desarrollado para determinar la estrategia que se utilizará para lograr la continuidad del negocio. En esta estrategia, hay que determinar, por ejemplo, el intervalo de tiempo aceptable para la recuperación de los sistemas críticos.

Con eso, se dan las condiciones para decidir cómo y dónde invertir en medidas de seguridad, protegiendo los activos y manteniendo las actividades dentro de su mayor normalidad. Una vez desarrollado el plan, que debe ser validado e implementado por los dirigentes de la organización.

Ejercicio de refuerzo - análisis de riesgos y continuidad de negocio

» ¿Cuál es el propósito de realizar un análisis de riesgos en la gestión de la continuidad del negocio?

9.5 Plan de continuidad del negocio

Este tema mostrará las etapas de la implementación de un plan de continuidad de negocio típicamente propuesto para las organizaciones reales, con el fin de tener en cuenta todos los requisitos de seguridad de la información para la continuidad del negocio.

1. Estructura

La estructura de un plan de continuidad de negocio normalmente debe incluir:

» Responsabilidades individuales necesarias para cada una de las actividades propuestas en el plan;
» Indicación de un gestor específico;
» Las condiciones necesarias para la activación del plan, por ejemplo, la forma de evaluar el efecto adverso, quién notificar, etc.;
» Los procedimientos para garantizar la operación temporal de los procesos y sistemas de negocios, mientras se está ejecutando la recuperación;
» Los procedimientos de emergencia para situaciones en las que hay incidentes que afectan directamente a los negocios;
» Procedimientos de recuperación de procesos y operaciones de negocio en un rango de tiempo aceptable;
» Especificación del calendario de mantenimiento y pruebas a los planes;
» Promoción del entrenamiento en relación con la continuidad del negocio.

2. Desarrollo e implementación

Durante la planificación de la continuidad del negocio, algunos elementos son determinantes e indican el contenido que se incluirá en el plan, con miras también a la seguridad de la información:

- Identificación de las responsabilidades y los procedimientos para la continuidad del negocio;
- Grado de identificación aceptable de pérdidas de información y servicios;
- La aplicación de los procedimientos de recuperación de las operaciones del negocio y la disponibilidad de información, teniendo en cuenta el marco de tiempo aceptable para restaurar el funcionamiento normal de las operaciones;
- La conciencia de las personas en función de sus responsabilidades y el conocimiento de los procedimientos involucrados;
- Pruebas;
- El mantenimiento regular del plan con el fin de reflejar los cambios significativos en el negocio de la organización.

Es importante tener en cuenta todas las dependencias externas a la organización y los contratos existentes, en particular lo que dice en relación con la legislación específica aplicable. Se recomienda también que se mantenga (actualizados y protegidos) copias del plan de continuidad de negocio en ambientes remotos, como medida de contingencia para situaciones de desastre.

Ejercicio de refuerzo – desarrollo e implementación

- En el entorno de su organización, nombre de tres elementos que son cruciales en la planificación de la continuidad del negocio.

9.5.3 Pruebas

El plan de continuidad del negocio debe probarse periódicamente como una forma de asegurar su actualización y eficiencia. Las pruebas también deben asegurarse de que todos los miembros del equipo de recuperación y demás personal relevante tienen conocimiento de los planes.

Las pruebas deben indicar cómo y cuándo cada uno de sus componentes debe ser probada. Se recomienda probar los componentes individuales de los planes a menudo. Varias técnicas pueden ser utilizadas para asegurar la exactitud con la cual los planes operarán en la vida real.

Entre ellos, se destacan:

- Prueba de diferentes escenarios (discutiendo los acuerdo de recuperación, por ejemplo, usando interrupciones);
- Simulaciones (particularmente útiles para el entrenamiento del personal en sus puestos y funciones de gestión de la crisis);
- Pruebas de recuperación técnica (garantizando que los sistemas de información pueden ser efectivamente recuperados);
- Prueba de recuperación en un sitio alternativo (ejecutando los procesos de negocio de forma paralela con las operaciones de recuperación fuera de la sede principal);
- Pruebas de las instalaciones de los proveedores de servicios (asegurando que los servicios y productos suministrados por fuentes externas cumplen con los requisitos contratados);
- Ensayo completo (probando la organización, el personal involucrado, los equipos, las instalaciones de procesamiento y los procesos para confirmar que pueden enfrentar y superar las interrupciones del entorno de operación).

9.5.4 Mantenimiento y reevaluación

El plan de continuidad del negocio debe someterse a mantenimiento e intervalos regulares de tiempo, y actualizarse para asegurar su efectividad. Además de los cambios en los negocios, entre otros, se presentan a continuación, que pueden indicar la necesidad de mejoras en el plan, las pruebas realizadas deben estar completamente documentadas y sirven como fuente de datos para las actualizaciones.

Los cambios relevantes a ser considerados en el mantenimiento del plan incluyen la adquisición de nuevos equipos, nuevos sistemas (o actualización de los mismos), los cambios en las estrategias de negocio y los cambios en la legislación.

Se recomienda establecer responsabilidades para las revisiones regulares. La identificación de los cambios que han ocurrido en el negocio, pero aún no incluidas en el plan es una señal de que existe la necesidad de mantenimiento. El proceso de control de cambios debe garantizar que los planes actualizados serán distribuidos entre los sectores responsables (y para la sede remota, apropiadamente).

Ejemplo de recomendación para la continuidad del negocio: comprometiendo el entorno de las TI:

- "En caso de comprometimiento probado de seguridad del entorno de las TI por algún acontecimiento imprevisto, todas las

claves de acceso se deben cambiar. En estos casos, una versión segura del sistema operativo y del software de seguridad se debe descargar de nuevo, y los cambios recientes a los usuarios y los privilegios del sistema deben revisarse para detectar modificaciones no autorizadas a los datos."

El ejemplo presenta procedimientos recomendados que serán activados debido a la ocurrencia de desastres en el medio ambiente de las TI, cuyo objetivo es la continuidad del negocio.

Ejemplo de directriz para la concientización sobre la seguridad de la información y la continuidad del negocio:

» "La divulgación de reglas, riesgos, procedimientos y políticas de seguridad a los usuarios finales debe ser objeto de permanentes campañas internas, seminarios de sensibilización y cualquier otro medio o iniciativas para la consolidación de la educación para la seguridad de la información."

La directriz mostrada en el ejemplo comprende directamente la preocupación sobre la seguridad de la información y por consiguiente apoya en el sentido de garantizar la continuidad del negocio de la organización.

Los bancos Centrales y organismos reguladores del mercado financiero han emitido circulares normatizando la necesidad de las entidades reguladas elaboren un plan de continuidad de negocios, que cumplan con los siguientes elementos:

» Las entidades deben definir, imple- mentar, probar y mantener un proceso para administrar la con- tinuidad del negocio que incluya la prevención y atención de emergencias, administración de la crisis, planes de contingencia y capacidad de retorno a la operación normal.
» Sistema de Control Interno: implementar, probar y mantener un proceso para administrar la continuidad de la operación de la entidad para responder a las fallas e inte- rrupciones específicas de un sistema o proceso y capacidad de retorno a la normalidad.

Ejercicio de nivelación - la gestión de incidentes de seguridad

» ¿Qué entiende usted por incidente de seguridad?
» ¿Qué se hace con los incidentes de seguridad en su institución?

En este tema serán presentados algunos de los principales aspectos de la seguridad de la información en las organizaciones: gestión de incidentes de seguridad, presentando así las preocupaciones con respecto a la notificación de incidentes y procedimientos necesarios para su gestión.



Estudie la sección 13. Gestión de incidentes de seguridad de la información y la mejora de la norma ISO/IEC 27002:2007. **Norma Española 2022 apartados 5.29 a 5.31 inclusive**

La gestión de incidentes de seguridad de la información incluye una definición de responsabilidades y los procedimientos para el control efectivo de los eventos adversos (incidentes) después de la notificación. Por lo tanto, la gestión de incidentes involucra procedimientos para reportar los eventos adversos y la aplicación de medidas de seguridad adecuadas para su resolución. Vale la pena señalar que, además de la notificación, es importante un seguimiento efectivo de la organización como un medio para detectar los incidentes de seguridad.

9.6 Notificación de eventos adversos

Una serie de eventos adversos (incidentes o de seguridad) puede ocurrir en las organizaciones, como por ejemplo, pérdida de equipos y recursos, sobrecarga de sistemas; violaciones de los controles de acceso físico/lógico; malfuncionamiento de hardware/software, códigos maliciosos, negación de servicio (*Denial of Service,* DoS), uso inapropiado de los sistemas de información, entre otros.

El reporte de eventos adversos se debe hacer para aplicar las medidas correctivas adecuadas en el momento oportuno. Por lo tanto, es importante que todas las personas (empleados, contratistas, etc.) estén informadas acerca de los procedimientos formales para la notificación y por lo tanto se convierten en responsables de notificar cualquier evento adverso o vulnerabilidad que podría afectar la seguridad de la información de la organización.

Es de destacar que las notificaciones deberán ser enviadas al responsable (persona o equipo) directo de recibirlas en la organización. Por lo tanto, es importante identificar formalmente y por anticipado quién es la persona responsable. Por otra parte, se puede utilizar herramientas tales como formularios específicos para ayudar a las personas en la elaboración de la notificación y en el registro del evento adverso.

Ejercicio de refuerzo - notificación de los eventos adversos

» ¿Cuál es el propósito de la notificación de eventos adversos?

9.7 Procedimientos de gestión de incidentes de seguridad

Para la gestión de los incidentes de seguridad, debemos establecer los procedimientos adecuados a seguir después de su notificación. Estos procedimientos deben incluir las medidas efectivas que se adopten de manera ordenada y rápida.

Los procedimientos de gestión de incidentes de seguridad deben contemplar:

» Planes de contingencia;
» Identificación y análisis de la causa del incidente de seguridad. El análisis, en particular, proporcionar información sobre los tipos, cantidades y costos relacionados con los incidentes de seguridad con el fin de dar una idea del impacto de su ocurrencia a la organización (el negocio, principalmente) y por lo tanto dar indicios sobre necesidades en cuanto a la acción a tomar;
» Planificación y ejecución de medidas correctivas para evitar que se repita el incidente.

Una pregunta relevante se debe considerar: mantenimiento de procedimientos que determinan a quién contactar y cuándo ponerse en contacto en caso de incidentes relacionados con las autoridades, tales como estaciones de bomberos y agentes de vigilancia. El mantenimiento de esta información es importante tanto para la gestión de incidentes de seguridad como para la gestión de la continuidad del negocio.

Acompañados por legislaciones y normativas los países fijan permanentemente lineamientos de política en ciberseguridad y ciberdefensa orientados a desarrollar una estrategia nacional que contrarreste el incremento de las amenazas informáticas que afectan significativamente al país. Adicionalmente, recoge los antecedentes nacionales e internacionales, así como la normatividad del país en torno al tema.

Ejercicio de refuerzo - procedimientos de gestión de incidentes de seguridad

» ¿Qué procedimientos se deben considerar en la gestión de los incidentes de seguridad?

9.8 Planes de contingencia

Se presentarán los siguientes aspectos de la importancia de los planes de contingencia en las organizaciones y sus fases de planeamiento.

Implementar (planear, elaborar e implantar) un plan de contingencia involucra recursos financieros, acuerdos, cooperación de los empleados, y con frecuencia la asistencia de consultores técnicos externos y empresas especializadas en seguridad o seguros. Además, también se debe considerar los costos relacionados con entrenamiento, pruebas y mantenimiento del plan.

Un plan de contingencia debe incluir dos fases: la respuesta inmediata a los desastres (incluyendo incidentes de seguridad) y proceso de recuperación. En la primera fase, se deben considerar las decisiones gerenciales sobre las medidas que se aplicarán y, en la segunda fase, hay que definir los procedimientos necesarios para restaurar las funciones, los sistemas y recursos. El plan de contingencia puede incluir diferentes etapas (y complementarias) de recuperación, de modo que, a lo largo del tiempo, sea restablecido el funcionamiento normal de la organización.

A continuación se describen las fases que componen la planificación de contingencias y sus detalles.

Antes del planeamiento, es importante responder a las siguientes preguntas:

- ¿Cuáles son los objetivos?
- ¿Cuál es el presupuesto?
- ¿Cuáles son los plazos?
- ¿Cuáles son los recursos humanos disponibles?
- ¿Cuáles son los equipos y otros suplementos necesarios?
- ¿Cuáles son las responsabilidades del equipo responsables de la planificación?

Con todas las respuestas, usted puede comenzar el plan de contingencias, siguiendo las fases:

- Las actividades preliminares, que implican la conciencia de los líderes de la organización, la identificación de los recursos y la información crítica, análisis de costos y definición de plazos;
- Análisis de impacto, para identificar los impactos causados por la interrupción de los servicios proporcionados por el sistema informático de cada organización, teniendo en cuenta, por lo tanto, la importancia de cada uno de ellos para la continuidad del negocio;
- El análisis de alternativas de recuperación, que procura verificar la relación costo/beneficio de las diversas opciones para la recuperación de desastres. Es importante que, justo después de esta etapa, sea elaborado y se entregue a los líderes de la organización un documento informando el análisis y recomendaciones para la continuidad del negocio;
- Desarrollo del plan de contingencia después de analizar el informe presentado al final de la fase anterior, tiene como objetivo elaborar el contenido del plan;
- Entrenamiento, con el objetivo de concientizar a las personas acerca de sus responsabilidades con respecto al plan;
- Prueba del plan de contingencias, buscando identificar las mejoras a través de adaptaciones o correcciones;
- Evaluación de los resultados y actualización del plan, en el cual los resultados de las pruebas son evaluados e iniciando el proceso de modificar el plan conforme a las mejoras propuestas.

Las actividades preliminares

- Las iniciativas para la concientización de los dirigentes.
- Estudio preliminar de los recursos, los sistemas y las funciones críticas del negocio
- Las actividades preliminares de planificación de contingencias cubren básicamente todas las iniciativas de sensibilización de líderes sobre las necesidades y un estudio preliminar sobre los ítems críticos para la organización.



No se puede implementar un plan de contingencia sin una sensibilización de los dirigentes de la organización, y mucho menos sin su apoyo total.

En el estudio preliminar de los servicios críticos, son recopilados recursos, sistemas y funciones críticas de los negocio de la organización, así como el costo, los plazos y los recursos humanos necesarios en la realización del análisis de impacto (la próxima fase de planificación). Note aquí la importancia de presentar este estudio a los líderes de la organización, con la intención de obtener su aprobación.

Ejercicio de refuerzo - los planes de contingencia

- ¿ Cuáles son las fases de un plan de contingencias y qué debe ser considerado en cada fase?
- ¿ Cuáles son las actividades preliminares de la planificación de contingencia?

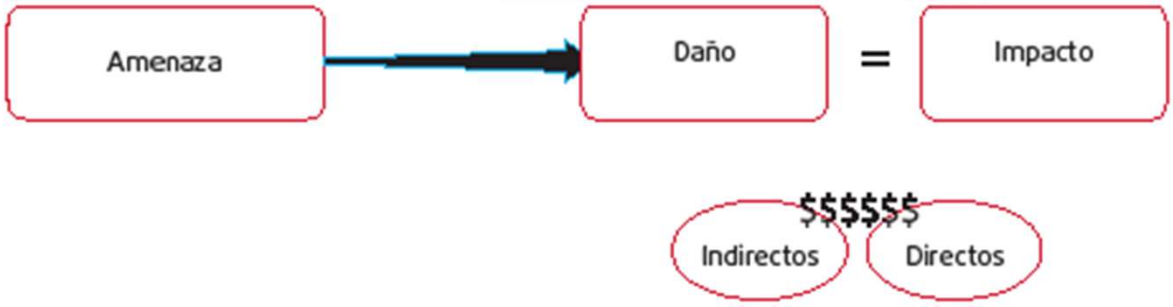
9.9 Análisis de impacto

En esta fase se identifican y se clasifican, de acuerdo con su importancia para el negocio de la organización, las funciones, los sistemas y recursos, teniendo en cuenta, por tanto, las posibles amenazas a que están expuestos. Este análisis es un elemento importante para que los dirigentes puedan tomar decisiones con respecto a las inversiones que serán aplicadas en medidas de seguridad para la continuidad de su negocio.

En el proceso de análisis de impacto, es importante llevar a cabo entrevistas con los diferentes gerentes de los sectores específicos y críticos para los negocios de la organización, equipos de soporte y usuarios de sistemas.

El análisis de impacto se puede dividir en tres sub-fases: identificación de recursos, funciones y sistemas críticos, definición del tiempo para la recuperación y elaboración de informes.

Figura 29. Secuencia hasta el impacto



Ejercicio de refuerzo - análisis de impacto

» Especifique las sub-fases de un análisis de impacto.

9.10 Identificación de recursos, funciones y sistemas críticos

En esta sub-fase, se debe considerar tanto la identificación de los recursos, funciones y sistemas críticos, como su clasificación. La siguiente es una propuesta de clasificación que se puede utilizar en organizaciones reales:

» Altamente importante (esenciales);
» Importancia media;
» Baja importancia.



Tenga en cuenta que la identificación y clasificación generan datos escenciales para la toma de decisiones en relación con el alcance del plan de contingencia, garantizando el funcionamiento de la organización en un nivel de servicio aceptable.

9.11 Definición del tiempo para la recuperación y elaboración del informe

En la sub-fase de definición del tiempo para la recuperación se determina el rango de tiempo aceptable de indisponibilidad de cada función, recurso y sistema de acuerdo con la criticidad y el impacto relativo. Como resultado se tiene un intervalo de tiempo aceptable para la recuperación del recurso, sistema o función.

En el informe, se debe destacar:

- Los recursos, los sistemas y las funciones identificadas y clasificadas por orden de importancia para la organización;
- Una descripción de las amenazas potenciales para cada recurso, sistema y función;
- El rango de tiempo tolerable para la recuperación de cada recurso, sistema y función;
- La recopilación de la información sobre recursos humanos, instalaciones, equipos y servicios requeridos para la restauración y la recuperación de cada recurso, sistema y función.

Al final de las tres sub-fases el informe permitirá a los líderes de la organización la toma de decisiones con respecto a la implementación del plan de contingencia.

9.12 Análisis de alternativas de recuperación

En esta fase, las alternativas, tales como la prevención y la detección de accidentes, control de *backups*, estrategias confiables para almacenar y recuperar datos, seguros, redundancia de sistemas y recursos, entre otras alternativas de recuperación en caso de desastres son analizadas y seleccionadas para ser implantadas en casos específicos de necesidad de contingencia, teniendo en cuenta los resultados obtenidos en las etapas anteriores de planificación.

En términos de prevención y detección de accidentes, se recomienda tener en cuenta los equipos de detección y extinción de incendios; el mantenimiento preventivo de los equipos, la protección de los documentos no magnéticos (impresos, por ejemplo); la seguridad adecuada de los recursos humanos, etc.

La política de *backup* es uno de los elementos más importantes de un plan de contingencia, después de todo, un sistema que ha experimentado problemas se puede comparar con su *backup* (si se mantiene actualizado y completo), lo que permite su restauración. Por lo tanto, es la política de copia de seguridad la que determina todos los procedimientos necesarios para la protección de la información de la organización de acuerdo a su importancia para el negocio. Recuerde que la infraestructura y los procedimientos de *backup* deben someterse a pruebas regulares, para que la recuperación en caso de problemas de seguridad esté realmente asegurada.

En términos de almacenamiento de datos, se debe considerar la seguridad adecuada aplicada a los medios y el lugar de almacenamiento utilizado, inclusive teniendo en cuenta el almacenamiento remoto de las copias de seguridad. Para la recuperación de los datos almacenados, se recomienda comprobar regularmente los procedimientos de restauración utilizados. Recuerde que si la recuperación de los datos fracasa, de nada sirve mantener las copias de seguridad.

También se debe considerar la posibilidad de contratar un seguro para cubrir posibles pérdidas causadas por incidentes de seguridad.

Ejercicio de refuerzo - análisis de alternativas de recuperación

» ¿Por qué una política de *backup* es importante en un plan de contingencia?

13. Informes de alternativas de recuperación

Después del análisis de las alternativas se debe elaborar un informe detallado sobre las opciones de recuperación, estimaciones de costos, ventajas y desventajas de cada alternativa.

Tenga en cuenta también los recursos humanos, financieros y de infraestructura necesarios para la próxima fase. Este informe también prestará apoyo a la dirección de la organización en la toma de decisiones estratégicas en relación con el plan de contingencia.

14. El desarrollo del plan de contingencia

Durante el desarrollo de un plan de contingencia se debe prestar atención a las siguientes pautas:

» Designar un equipo para implementar el plan de contingencia, inclusive dividiéndolo por área de actuación. Por ejemplo, el equipo gerencial, que se ocupará de la coordinación de las actividades relacionadas, y el equipo de respuesta inmediata a incidentes que activan las medidas apropiadas a los incidentes de seguridad ocurridos;
» Determinar la forma de responder a los desastres en el momento oportuno, abarcando la identificación y comprensión del problema, contención de daños; identificación de daños causados; restauración de los sistemas y eliminación de las causas de los desastres;
» Identificar los aplicativos críticos, a los que se deben aplicar las medidas de emergencia en situaciones de desastre;
» Mantener un registro (o inventario) de archivos, datos, programas, sistema operativo y utilitarios relacionados con los aplicativos críticos, asegurando que todos están incluidos en los procedimientos de respaldo y recuperación;
» Recopilar las necesidades de condiciones especiales requeridas por las redes de comunicación;

» Tener en cuenta la retirada del personal y la garantía de la seguridad de los documentos en papel y medios magnéticos.

9.15 Entrenamientos y pruebas

Se deben considerar en esta fase iniciativas para crear conciencia en los empleados y terceros en relación con el plan de contingencia de la organización. Por lo tanto, los entrenamientos deben ser regulares, involucrando la teoría, la práctica y las simulaciones.

Una de las garantías que la organización puede considerar, en términos de plan de contingencias, es el resultado de las pruebas que se le aplican. En términos prácticos, las pruebas se pueden clasificar en las siguientes categorías:

» Integral, involucrando situaciones cercanas a la realidad de la organización, por ejemplo, contemplando la verificación de procedimientos de traslado de personas y procesamiento a los sitios alternos;
» Parcial, limitada a partes del plan de contingencia o a determinadas actividades o aplicativos;
» Simulada, considerando representaciones de la situación de desastre, por ejemplo, la evacuación del edificio de la organización en un simulacro de incendio.

Durante las pruebas, se debe cronometrar todos los eventos relacionados y registrar cualquier problema que ocurra, si es posible indicando una clasificación de acuerdo a su gravedad.

Ejercicio de refuerzo - formación y pruebas

» ¿Cómo se pueden clasificar las pruebas?

9.16 Evaluación y actualización del plan

Debido a los cambios en los objetivos de negocio, cambios administrativos y en el ambiente computacional, por ejemplo, también se debe actualizar el plan de contingencia, de manera que este refleje los cambios, minimizando los impactos causados por fallas de seguridad.

Los ejemplos de las recomendaciones para la prevención de incidentes de seguridad de la información:

- "no está permitido, a menos que se cuente con la debida autorización, interferir, sobrecargar o deshabilitar un servicio, incluyendo unirse o cooperar con ataques de negación de servicios internos o externos."
- "Se prohíbe a los usuarios la ejecución de pruebas o tentativas que comprometa los controles internos. Esta práctica sólo se permite a personas con competencia y función técnica en la organización, durante actividades de monitoreo y análisis de riesgos, con la autorización legítima para hacerlo."

Estos ejemplos presentan algunas recomendaciones que podrían ser parte de la política de seguridad o de las directrices para la seguridad de la información, enfocados a la ocurrencia de incidentes de seguridad. Todas las recomendaciones se consideran genéricas y aplicables a organizaciones reales.

9.17 Buenas prácticas

En la búsqueda de una adecuada gestión de incidencias y un plan de contingencia efectivo para una organización, se recomiendan algunas prácticas:

- Documentar todos los incidentes de seguridad y las acciones tomadas, para permitir una investigación posterior de las causas;
- Identificar recursos, funciones y sistemas críticos y sus prioridades para el negocio;
- Analizar el impacto causado por las amenazas de seguridad de la organización;
- Evaluar las alternativas de recuperación, buscando identificar las más adecuadas para el contexto;
- Elaborar el plan de contingencias de acuerdo con los recursos disponibles (financieros, recursos humanos y de infraestructura);
- Entrenar a las personas, concientizándolas sobre sus responsabilidades acerca del plan de contingencias;
- Llevar a cabo pruebas periódicas del plan de contingencias y los procedimientos de recuperación establecidos en la organización.